
***Course Name: INT302: WEB APPLICATION
RECONNAISSANCE TOOLS***

Executive Summary

This comprehensive lab enhanced practical experience in web application reconnaissance and information gathering techniques essential for cybersecurity professionals. Key activities included domain reconnaissance through IP identification and WHOIS lookups, technology fingerprinting using WhatWeb, subdomain enumeration with multiple tools, directory discovery using Dirb, vulnerability scanning with Nmap and Nikto, and database exploration on intentionally vulnerable systems. The lab successfully demonstrated reconnaissance methodologies against real-world domains (icdfa.edu.ng, nasarawastate.gov.ng, icdfa.org.ng) and vulnerable targets (OWASP BWA). Through systematic execution and documentation, practical proficiency was achieved in passive and active information gathering, comparative tool analysis, and automated reconnaissance scripting. A custom Bash reconnaissance automation tool was developed to streamline repetitive tasks.

Lab Objectives

The primary objectives of this lab were to:

1. Develop proficiency in domain reconnaissance through IP identification, WHOIS lookups, and DNS enumeration
2. Master technology fingerprinting techniques using WhatWeb for identifying web server technologies and frameworks
3. Understand and execute subdomain enumeration using multiple tools (Sublist3r and KnockPy) with comparative analysis
4. Learn directory discovery techniques using Dirb to identify hidden files and directories on web servers
5. Practice port scanning and vulnerability detection using Nmap and Nikto for identifying security weaknesses
6. Develop Bash scripting skills to automate reconnaissance workflows and improve efficiency
7. Gain fundamental understanding of HTTP request methods (GET vs POST) and the web request-response model
8. Apply learned skills to real-world domains and vulnerable environments with proper documentation practices

Tools and Resources Used

Operating Systems:

- **Kali Linux** - Debian-derived Linux distribution designed for penetration testing and digital forensics
- **Metasploitable2** - Intentionally vulnerable Linux virtual machine for security testing

- **OWASP BWA (Broken Web Applications)** - Vulnerable web application collection for security training

Core Reconnaissance Tools:

<i>Tool</i>	<i>Description</i>
<i>WhatWeb</i>	Web scanner for technology fingerprinting and identifying CMS, frameworks, and server information
<i>Sublist3r</i>	Python-based subdomain enumeration tool using OSINT techniques
<i>KnockPy</i>	Subdomain enumeration tool with DNS reconnaissance capabilities
<i>Dirb</i>	Web content scanner for discovering hidden directories and files using wordlist-based brute forcing
<i>Nmap</i>	Network exploration and security auditing tool for port scanning and service detection
<i>Nikto</i>	Web server vulnerability scanner for identifying common security issues and misconfigurations
<i>MySQL Client</i>	Command-line interface for database interaction and exploration
<i>whois</i>	Domain registration information lookup tool
<i>dig/nslookup</i>	DNS query tools for domain name resolution

Table 1: Core tools used and their descriptions.

Internet Access - Required for domain and subdomain enumeration tasks

Methodology

Part 1: Domain Reconnaissance - IP Address, WHOIS, and DNS Lookup

Target Domains:

- ✓ icdfa.edu.ng
- ✓ nasarawastate.gov.ng
- ✓ icdfa.org.ng

Commands Used:

```
ladesha@kali ~
Session Actions Edit View Help
GNU nano 8.7 web_reconnaissance.sh
!l/bin/bash

echo "🔴 Starting Basic Reconnaissance"
echo "===== "
echo "Enter the domain:"
read domain
echo " "

get_info() {
echo "Getting IP Address"
echo "===== "

IP_ADDRESS=$(dig "$domain" A +short)
echo "IP ADDRESS: $IP_ADDRESS"
echo " "

echo "■ WHOIS Analysis for $domain"
echo "===== "

Registration=$(whois "$domain")

if [ -z "$Registration" ]; then
echo "❌ Could not resolve registration and ownership details for $domain"

else
echo "👉 WHOIS INFORMATION: $Registration"

fi
echo " "

echo "🌐 DNS Analysis for $domain"
echo "----- "
echo "↑ A Records (IPv4):"
dig "$domain" A +short
echo " "
echo "■ MX Records (Mail Servers):"
dig "$domain" MX +short
echo " "
echo "🌀 NS Records (Name Servers):"
dig "$domain" NS +short
echo " "
}

get_info $domain
```

Figure 1:Depiction of commands used in the script.

```
(ladesha@kali)-[~]
$ nano web_reconnaissance.sh

(ladesha@kali)-[~]
$ ./web_reconnaissance.sh
🔴 Starting Basic Reconnaissance
=====
Enter the domain:
icdfa.edu.ng

Getting IP Address
=====
IP ADDRESS: 131.153.147.186

■ WHOIS Analysis for icdfa.edu.ng
=====
connect: Network is unreachable
❌ Could not resolve registration and ownership details for icdfa.edu.ng

🌐 DNS Analysis for icdfa.edu.ng
-----
↑ A Records (IPv4):
131.153.147.186

■ MX Records (Mail Servers):
0 ICDFA.EDU.NG.

🌀 NS Records (Name Servers):
nsc.go54.com.
nsd.go54.com.
```

```
(ladesha@kali)-[~]
$ ./web_reconnaissance.sh
● Starting Basic Reconnaissance

Enter the domain:
nasarawastate.gov.ng

Getting IP Address
IP ADDRESS: 181.215.243.156

■ WHOIS Analysis for nasarawastate.gov.ng
connect: Network is unreachable
✗ Could not resolve registration and ownership details for nasarawastate.gov.ng

● DNS Analysis for nasarawastate.gov.ng
-----
↑ A Records (IPv4):
181.215.243.156

■ MX Records (Mail Servers):
0 nasarawastate.gov.ng.

🔗 NS Records (Name Servers):
ns77.qservers.net.
ns78.qservers.net.

(ladesha@kali)-[~]
$ ./web_reconnaissance.sh
● Starting Basic Reconnaissance

Enter the domain:
icdfa.org.ng

Getting IP Address
IP ADDRESS: 131.153.147.186

■ WHOIS Analysis for icdfa.org.ng
connect: Network is unreachable
✗ Could not resolve registration and ownership details for icdfa.org.ng

● DNS Analysis for icdfa.org.ng
-----
↑ A Records (IPv4):
131.153.147.186

■ MX Records (Mail Servers):
0 icdfa.org.ng.

🔗 NS Records (Name Servers):
nsc.go54.com.
nsd.go54.com.
```

Figure 2: Output of running the script `./web_reconnaissance.sh` using different domains

Part 2: Technology Fingerprinting with WhatWeb

2.1: Performing basic and aggressive scan

Commands Used:

whatweb `http://192.168.0.105`

whatweb `--aggression 3 -v 192.168.0.105`

```
ladesha@ladesha: ~  
Session Actions Edit View Help  
  
(ladesha@ladesha)-[~] View Help  
$ whatweb http://192.168.0.105  
http://192.168.0.105 [200 OK] Apache[2.2.14][mod_mono/2.4.3,mod_perl/2.0.4,mod_python/3.3.1,mod_ssl/2.2.14,proxy_html/3.0.1], Country[RESERVED][22], Email[admin@metacorp.com,admin@owaspbwa.org,bob@ateliergraphique.com,cycloneuser-3@cyclonetransfers.com,jack@metacorp.com,test@thebodgeitstore.com], HTML5, HTTPServer[Ubuntu Linux][Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/v5.10.1], IP[192.168.0.105], JQuery[1.3.2], OpenSSL[0.9.8k], PHP[5.3.2-1ubuntu4.30][Suhosin-Patch], Passenger[4.0.38], Perl[5.10.1], Python[2.6.5], Script[text/javascript], Title[owaspbwa OWASP Broken Web Applications]  
  
(ladesha@ladesha)-[~] View Help  
$ whatweb --aggression 3 -v 192.168.0.105  
WhatWeb report for http://192.168.0.105  
Status : 200 OK  
Title : owaspbwa OWASP Broken Web Applications  
IP : 192.168.0.105  
Country : RESERVED, 22  
  
Summary : Apache[2.2.14][mod_mono/2.4.3,mod_perl/2.0.4,mod_python/3.3.1,mod_ssl/2.2.14,proxy_html/3.0.1], Email[admin@metacorp.com,admin@owaspbwa.org,bob@ateliergraphique.com,cycloneuser-3@cyclonetransfers.com,jack@metacorp.com,test@thebodgeitstore.com], HTML5, HTTPServer[Ubuntu Linux][Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/v5.10.1], JQuery[1.3.2], OpenSSL[0.9.8k], Passeng
```

Figure 3:Output from using the whatweb tool

2.2: Comparison of Basic vs Aggressive Scans

Aspect	Basic Scan	Aggressive Scan
Speed	Faster execution	Slower, more thorough
Detail Level	Surface-level information	Deep technology stack analysis
Detection Methods	Passive observation	Active probing and interaction
Information Gathered	Basic server/framework info	Detailed versions, plugins, configurations
Stealth	Less likely to trigger IDS/IPS	More detectable by security systems

Table 2: In-depth difference between basic and aggressive scans

Part 3: Website Enumeration and Information Gathering

3.1: Server Banner Grabbing

Commands Used:

```
curl -I http://192.168.0.105
```

```
(ladosha@ladosha)~$ curl -I http://192.168.0.105
HTTP/1.1 200 OK
Date: Fri, 26 Dec 2025 09:02:57 GMT
Server: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/v5.10.1
Last-Modified: Fri, 31 Jul 2015 02:55:52 GMT
ETag: "45f13-6da3-51c22f5365e00"
Accept-Ranges: bytes
Content-Length: 28867
Vary: Accept-Encoding
Content-Type: text/html
```

Figure 4:Results from running curl command against OWASP Ip address

Identified Information:

HEADERS	DETAILS IDENTIFIED
HTTP STATUS	200 Ok
OPERATING SYSTEM	Ubuntu Linux
CONTENT-TYPE	Text/html
CONNECTION	Close
SSL LIBRARY	OpenSSL 0.9.8K
ENABLED APACHE MODULES	mod_mono/2.4.3, mod_perl/2.0.4, mod_python/3.3.1, mod_ssl/2.2.14, proxy_html/3.0.1
APPLICATION SERVER	Phusion Passenger 4.0.38

Table 3: Headers identified by the Curl command

3.2: Framework and CMS Detection

Commands Used:

```
whatweb -v 192.168.0.105
```

```
ladesha@ladesha:~$ whatweb -u 192.168.0.105
WhatWeb report for http://192.168.0.105
Status : 200 OK
Title : OWASP Broken Web Applications
IP : 192.168.0.105
Country : 8642420, 22

Summary : Apache[2.2.14](mod_mono/2.4.3,mod_perl/2.0.4,mod_python/3.3.1,mod_ssl/2.2.14,proxy_html/3.0.1), Email[admin@metacorp.com,admin@owaspbwa.org,bob@ateliertagraphe.com,cycloneuser-3@cyclonetransfers.com,jack@metacorp.com,test@thebodgeitstore.com], HTMLS, HTTPServer[Ubuntu], [Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/v5.10.1], JQuery[1.3.2], OpenSSL[0.9.8k], Passenger[4.0.38], Perl[5.10.1], Pp[5.3.2-1ubuntu4.30][Suhosin-Patch], Python[2.6.5], Script[text/javascript]

Detected Plugins:
[ Apache ]
The Apache HTTP Server Project is an effort to develop and maintain an open-source HTTP server for modern operating systems including Unix and Windows NT. The goal of this project is to provide a secure, efficient and extensible server that provides HTTP services in sync with the current HTTP standards.
Version : 2.2.14 (from HTTP Server Header)
Module : mod_mono/2.4.3,mod_perl/2.0.4,mod_python/3.3.1,mod_ssl/2.2.14
Module : proxy_html/3.0.1
Google Dorks: (3)
Website : http://httpd.apache.org/

[ Email ]
Extract email addresses. Find valid email address and syntactically invalid email addresses from mailto: link tags. We match syntactically invalid links containing mailto: to catch anti-spam email addresses, eg. bob at gmail.com. This uses the simplified email regular expression from http://www.regular-expressions.info/email.html for valid email address matching.
String : admin@metacorp.com,admin@owaspbwa.org,bob@ateliertagraphe.com,cycloneuser-3@cyclonetransfers.com,jack@metacorp.com,test@thebodgeitstore.com

[ HTMLS ]
HTML version 5, detected by the doctype declaration

[ HTTPServer ]
HTTP server header string. This plugin also attempts to identify the operating system from the server header.
OS : Ubuntu Linux
String : Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/v5.10.1 (fr
on server string)

[ JQuery ]
A fast, concise, JavaScript that simplifies how to traverse HTML documents, handle events, perform animations, and add AJAX.
Version : 1.3.2
Website : http://jquery.com/

[ OpenSSL ]
The OpenSSL Project is a collaborative effort to develop a robust, commercial-grade, full-featured, and Open Source toolkit implementing the Secure Sockets Layer (SSL v2/v3) and Transport Layer Security (TLS v1) protocols as well as a full-strength general purpose cryptography library.
Version : 0.9.8k
Website : http://www.openssl.org/

[ PHP ]
PHP is a widely-used general-purpose scripting language that is especially suited for Web development and can be embedded into HTML. This plugin identifies php errors, modules and versions and extracts the local file path and username if present.
Version : 5.3.2-1ubuntu4.30
Module : Suhosin-Patch
Google Dorks: (3)
Website : http://www.php.net/

[ Passenger ]
Phusion Passenger - a.k.a. mod_rails or mod_rack - makes deployment of Ruby web applications, such as those built on the revolutionary Ruby on Rails web framework, a breeze. It follows the usual Ruby on Rails conventions, such as "Don't Repeat Yourself" website "http://www.modrails.com/"
Version : 4.0.38

[ Perl ]
Perl is a highly capable, feature-rich programming language with over 22 years of development.
Version : 5.10.1 (from HTTP Server Header)
Website : http://www.perl.org/

[ Python ]
Python is a programming language that lets you work more quickly and integrate your systems more effectively. You can learn to use Python and see almost immediate gains in productivity and lower maintenance costs.
Version : 2.6.5 (from # Server # Version Detection)
Website : http://www.python.org/

[ Script ]
This plugin detects instances of script HTML elements and returns the script language/type.
String : text/javascript

HTTP Headers:
HTTP/1.1 200 OK
Date: Fri, 26 Dec 2025 09:20:04 GMT
Server: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/v5.10.1
Last-Modified: Fri, 31 Jul 2015 02:55:52 GMT
ETag: "45f13-6da3-51c22f536e00"
Accept-Ranges: bytes
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 4785
Connection: close
Content-Type: text/html
```

Figure 5:Output from whatweb command against the OWASP IP address

Web Server	Apache/2.2.14(Ubuntu)
CMS	Not explicitly detected by WhatWeb. However, directory enumeration revealed multiple Joomla-related directories, strongly indicating the presence of a Joomla CMS installation.

Technologies detected	a) PHP 5.3.2-1ubuntu4.30 b) Python 2.6.5 c) Perl 5.10.1 d) OpenSSL 0.9.8k e) Phusion Passenger/4.0.38 f) mod_perl/2.0.4 g) jQuery 1.3.2 h) HTML5
-----------------------	---

Table 4: Tabulation of what the output image above means

3.3: Misconfiguration and Information Leakage

- Exposed email addresses: admin@metacorp.com, admin@owasphwa.org, bob@ateliergraphique.com, and several others
- Verbose server banner revealing exact versions of Apache, PHP, Python, OpenSSL, and all loaded modules
- Old software versions: Apache 2.2.14 (from 2010), PHP 5.3.2 (2010), OpenSSL 0.9.8k (2009) - all outdated and potentially vulnerable
- ETag disclosure revealing inode information

Part 4: Subdomain Enumeration and Tool Comparison

4.1: Subdomain Enumeration Using Sublist3r

Installation (if needed):

`git clone https://github.com/aboul3la/Sublist3r.git`

`cd Sublist3r`

`pip install -r requirements.txt`

Commands Used:

`sublist3r -d icdfa.edu.ng -o icdfa_subdomains.txt`

`sublist3r -d nasarawastate.gov.ng -o nasarawa_subdomains.txt`

`sublist3r -d icdfa.org.ng -o icdfa_org_subdomains.txt`

```
ladesha@kali: ~/Sublist3r
Session Actions Edit View Help

(ladesha@kali)~-[~/Sublist3r]
$ sublist3r -d icdfa.edu.ng

Sublist3r
# Coded By Ahmed Aboul-Ela - @aboul3la

[-] Enumerating subdomains now for icdfa.edu.ng
[-] Searching now in Baidu..
[-] Searching now in Yahoo..
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Ask..
[-] Searching now in Netcraft..
[-] Searching now in DNSdumpster..
[-] Searching now in DNSrustotal..
[-] Searching now in ThreatCrowd..
[-] Searching now in SSL Certificates..
[-] Searching now in PassiveDNS..
Process DNSDumpster-8:
Traceback (most recent call last):
  File "/usr/lib/python3.13/multiprocessing/process.py", line 313, in _bootstrap
    self.run()
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 269, in run
    domain_list = self.enumerate()
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 649, in enumerate
    token = self.get_csrf_token(resp)
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 644, in get_csrf_token
    token = csrf_regex.findall(resp)[0]
IndexError: list index out of range
[-] Error: Virustotal probably now is blocking our requests
[-] Error: Google probably now is blocking our requests
[-] Finished now the Google Enumeration ---
[-] Total Unique Subdomains Found: 30
apply.icdfa.edu.ng
www.apply.icdfa.edu.ng
caps.icdfa.edu.ng
www.caps.icdfa.edu.ng
cvt.icdfa.edu.ng
www.cvt.icdfa.edu.ng
ctf.icdfa.edu.ng
www.ctf.icdfa.edu.ng
cybersmart.icdfa.edu.ng
www.cybersmart.icdfa.edu.ng
fellowship.icdfa.edu.ng
www.fellowship.icdfa.edu.ng
ijcf.icdfa.edu.ng
www.ijcf.icdfa.edu.ng
intranet.icdfa.edu.ng
www.intranet.icdfa.edu.ng
orientation.icdfa.edu.ng
www.orientation.icdfa.edu.ng
ortn.icdfa.edu.ng
www.ortn.icdfa.edu.ng
payment.icdfa.edu.ng
www.payment.icdfa.edu.ng
pcep.icdfa.edu.ng
www.pcep.icdfa.edu.ng
portal.icdfa.edu.ng
www.portal.icdfa.edu.ng
www.rc.icdfa.edu.ng
www.spt.icdfa.edu.ng
vdrp.icdfa.edu.ng
www.vdrp.icdfa.edu.ng
```

Figure 6: Screenshot of Sublist3r running against icdfa.edu.ng

```
Session Actions Edit View Help
(ladesha@kali) [~/Sublist3r]
$ sublist3r -d nasarawastate.gov.ng
```

SUBLIST3R

Coded By Ahmed Aboul-Ela - @aboul3la

```
[*] Enumerating subdomains now for nasarawastate.gov.ng
[*] Searching now in Baldu..
[*] Searching now in Yahoo..
[*] Searching now in Google..
[*] Searching now in Bing..
[*] Searching now in Ask..
[*] Searching now in Metacraft..
[*] Searching now in DNSdumpster..
[*] Searching now in Virustotal..
[*] Searching now in Threatcrowd..
[*] Searching now in SSL Certificates..
[*] Searching now in PassiveDNS..
[!] Error: Virustotal probably now is blocking our requests
Process DNSdumpster-8:
Traceback (most recent call last):
  File "/usr/lib/python3.13/multiprocessing/process.py", line 313, in _bootstrap
    self.run()
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 269, in run
    domain_list = self.enumerate()
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 649, in enumerate
    token = self.get_csrf_token(resp)
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 644, in get_csrf_token
    token = csrf_rex.findall(resp)[0]
IndexError: list index out of range
[!] Error: Google probably now is blocking our requests
[*] Finished now the Google Enumeration ...
[*] Total Unique Subdomains Found: 108
www.nasarawastate.gov.ng
asat2019.nasarawastate.gov.ng
www.asat2019.nasarawastate.gov.ng
asset.nasarawastate.gov.ng
www.asset.nasarawastate.gov.ng
backup.nasarawastate.gov.ng
www.backup.nasarawastate.gov.ng
bbb.nasarawastate.gov.ng
www.bbb.nasarawastate.gov.ng
bck.nasarawastate.gov.ng
www.bck.nasarawastate.gov.ng
bict.nasarawastate.gov.ng
www.bict.nasarawastate.gov.ng
bin.nasarawastate.gov.ng
www.bin.nasarawastate.gov.ng
bpp.nasarawastate.gov.ng
www.bpp.nasarawastate.gov.ng
contracts.nasarawastate.gov.ng
www.contracts.nasarawastate.gov.ng
covid19.nasarawastate.gov.ng
www.covid19.nasarawastate.gov.ng
```

```
cppanel.nasarawastate.gov.ng
cpcalendars.nasarawastate.gov.ng
cpcontacts.nasarawastate.gov.ng
csc.nasarawastate.gov.ng
www.csc.nasarawastate.gov.ng
dms.nasarawastate.gov.ng
www.dms.nasarawastate.gov.ng
emporium.nasarawastate.gov.ng
www.emporium.nasarawastate.gov.ng
export.nasarawastate.gov.ng
www.export.nasarawastate.gov.ng
finance.nasarawastate.gov.ng
www.finance.nasarawastate.gov.ng
hcd.nasarawastate.gov.ng
www.hcd.nasarawastate.gov.ng
cppanel.hcd.nasarawastate.gov.ng
cpcalendars.hcd.nasarawastate.gov.ng
cpcontacts.hcd.nasarawastate.gov.ng
webdisk.hcd.nasarawastate.gov.ng
webmail.hcd.nasarawastate.gov.ng
health.nasarawastate.gov.ng
www.health.nasarawastate.gov.ng
judiciary.nasarawastate.gov.ng
www.judiciary.nasarawastate.gov.ng
mail.nasarawastate.gov.ng
mfep.nasarawastate.gov.ng
www.mfep.nasarawastate.gov.ng
mofbef.nasarawastate.gov.ng
www.mofbef.nasarawastate.gov.ng
moj.nasarawastate.gov.ng
www.moj.nasarawastate.gov.ng
mtii.nasarawastate.gov.ng
www.mtii.nasarawastate.gov.ng
mtiitest.nasarawastate.gov.ng
www.mtiitest.nasarawastate.gov.ng
mwasd.nasarawastate.gov.ng
www.mwasd.nasarawastate.gov.ng
naepa.nasarawastate.gov.ng
www.naepa.nasarawastate.gov.ng
nasdsma.nasarawastate.gov.ng
www.nasdsma.nasarawastate.gov.ng
nasema.nasarawastate.gov.ng
www.nasema.nasarawastate.gov.ng
nasocp.nasarawastate.gov.ng
www.nasocp.nasarawastate.gov.ng
new.nasarawastate.gov.ng
www.new.nasarawastate.gov.ng
newsite.nasarawastate.gov.ng
www.newsite.nasarawastate.gov.ng
nigerianthisday.nasarawastate.gov.ng
www.nigerianthisday.nasarawastate.gov.ng
nqr.nasarawastate.gov.ng
www.nqr.nasarawastate.gov.ng
nscsc.nasarawastate.gov.ng
www.nscsc.nasarawastate.gov.ng
nssbp.nasarawastate.gov.ng
www.nssbp.nasarawastate.gov.ng
ocds.nasarawastate.gov.ng
www.ocds.nasarawastate.gov.ng
old.nasarawastate.gov.ng
```

```

moj.nasarawastate.gov.ng
www.moj.nasarawastate.gov.ng
mtii.nasarawastate.gov.ng
www.mtii.nasarawastate.gov.ng
ntlitest.nasarawastate.gov.ng
www.ntlitest.nasarawastate.gov.ng
mwad.nasarawastate.gov.ng
www.mwad.nasarawastate.gov.ng
naepa.nasarawastate.gov.ng
www.naepa.nasarawastate.gov.ng
nasdsma.nasarawastate.gov.ng
www.nasdsma.nasarawastate.gov.ng
nasema.nasarawastate.gov.ng
www.nasema.nasarawastate.gov.ng
nasocp.nasarawastate.gov.ng
www.nasocp.nasarawastate.gov.ng
new.nasarawastate.gov.ng
www.new.nasarawastate.gov.ng
newsite.nasarawastate.gov.ng
www.newsite.nasarawastate.gov.ng
nigerianthisday.nasarawastate.gov.ng
www.nigerianthisday.nasarawastate.gov.ng
nqr.nasarawastate.gov.ng
www.nqr.nasarawastate.gov.ng
nscsc.nasarawastate.gov.ng
www.nscsc.nasarawastate.gov.ng
nssbp.nasarawastate.gov.ng
www.nssbp.nasarawastate.gov.ng
ocds.nasarawastate.gov.ng
www.ocds.nasarawastate.gov.ng
old.nasarawastate.gov.ng
www.old.nasarawastate.gov.ng
pension.nasarawastate.gov.ng
www.pension.nasarawastate.gov.ng
sdgs.nasarawastate.gov.ng
www.sdgs.nasarawastate.gov.ng
sgs.nasarawastate.gov.ng
www.sgs.nasarawastate.gov.ng
sip.nasarawastate.gov.ng
www.sip.nasarawastate.gov.ng
sives.nasarawastate.gov.ng
www.sives.nasarawastate.gov.ng
ssg.nasarawastate.gov.ng
www.ssg.nasarawastate.gov.ng
stage.nasarawastate.gov.ng
www.stage.nasarawastate.gov.ng
stateaudit.nasarawastate.gov.ng
www.stateaudit.nasarawastate.gov.ng
tallafoundation.nasarawastate.gov.ng
www.tallafoundation.nasarawastate.gov.ng
thisday.nasarawastate.gov.ng
www.thisday.nasarawastate.gov.ng
tsc.nasarawastate.gov.ng
www.tsc.nasarawastate.gov.ng
webdisk.nasarawastate.gov.ng
webmail.nasarawastate.gov.ng
younikacademy.nasarawastate.gov.ng
www.younikacademy.nasarawastate.gov.ng

```

Figure 7: Screenshot of Sublist3r results for nasarawastate.gov.ng

```

(ladesha@kali)-[~/Sublist3r]
$ sublist3r -d icdfa.org.ng

Sublist3r

# Coded By Ahmed Aboul-Ela - @aboul3la

[-] Enumerating subdomains now for icdfa.org.ng
[-] Searching now in Baidu..
[-] Searching now in Yahoo..
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Ask..
[-] Searching now in Netcraft..
[-] Searching now in DNSdumpster..
[-] Searching now in Virustotal..
[-] Searching now in ThreatCrowd..
[-] Searching now in SSL certificates..
[-] Searching now in PassiveDNS..
[!] Error: Virustotal probably now is blocking our requests
[!] Error: Google probably now is blocking our requests
[!] Finished now the Google enumeration ...
Process DNSDumpster-8:
Traceback (most recent call last):
  File "/usr/lib/python3.13/multiprocessing/process.py", line 313, in _bootstrap
    self.run()
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 269, in run
    domain_list = self.enumerate()
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 649, in enumerate
    token = self.get_csrf_token(resp)
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 644, in get_csrf_token
    token = csrf_regex.findall(resp)[0]
IndexError: list index out of range
[-] Total Unique Subdomains Found: 1
portal.icdfa.org.ng

```

Figure 8: Screenshot of Sublist3r results for icdfa.org.ng

4.2: Installing and Running KnockPy

Commands Used:

knockpy -d icdfa.edu.ng --recon

knockpy -d nasarawastate.gov.ng --recon

knockpy -d icdfa.org.ng --recon

```

Session Actions Edit View Help
(knock-env)-(ladesha@kali)-[~/knock]
$ knockpy -d icdfa.edu.ng --recon
Reconnaissance ...
- VirusTotal: X
- Shodan: X
Scanned 28/28 domains ...

cbt.icdfa.edu.ng ['131.153.147.186']
http [None, None, None, None]
https [None, None, None, None]
cert [None, None, None, None]

icdfa.edu.ng ['131.153.147.186']
http [None, None, None, None]
https [None, None, None, None]
cert [None, None, None, None]

www.vdrp.icdfa.edu.ng ['131.153.147.186']
http [None, None, None, None]
https [None, None, None, None]
cert [None, None, None, None]

www.portal.icdfa.edu.ng ['131.153.147.186']
http [None, None, None, None]
https [None, None, None, None]
cert [None, None, None, None]

www.spt.icdfa.edu.ng ['131.153.147.186']
http [None, None, None, None]
https [None, None, None, None]
cert [None, None, None, None]

ortn.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://ortn.icdfa.edu.ng/', 'Apache', 274]
https [None, None, None, None]
cert [None, None, None, None]

www.cbt.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://www.cbt.icdfa.edu.ng/', 'Apache', 277]
https [None, None, None, None]
cert [None, None, None, None]

www.apply.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://www.apply.icdfa.edu.ng/', 'Apache', 279]
https [None, None, None, None]
cert [None, None, None, None]

www.ctf.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://www.ctf.icdfa.edu.ng/', 'Apache', 277]
https [None, None, None, None]
cert [None, None, None, None]

www.intranet.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://www.intranet.icdfa.edu.ng/', 'Apache', 282]
https [None, None, None, None]
cert [None, None, None, None]

ijcf.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://ijcf.icdfa.edu.ng/', 'Apache', 274]
https [None, None, None, None]
cert [None, None, None, None]

payment.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://payment.icdfa.edu.ng/', 'Apache', 277]
https [None, None, None, None]
cert [None, None, None, None]

www.orientation.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://www.orientation.icdfa.edu.ng/', 'Apache', 285]
https [None, None, None, None]
cert [None, None, None, None]

ctf.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://ctf.icdfa.edu.ng/', 'Apache', 273]
https [None, None, None, None]
cert [None, None, None, None]

www.fellowship.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://www.fellowship.icdfa.edu.ng/', 'Apache', 284]
https [None, None, None, None]
cert [None, None, None, None]

www.ortn.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://www.ortn.icdfa.edu.ng/', 'Apache', 278]
https [200, None, 'Apache', 482]
cert [True, '2026-01-26', 'www.ortn.icdfa.edu.ng', ['TLS 1.3']]

vdrp.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://vdrp.icdfa.edu.ng/', 'Apache', 274]
https [200, None, 'Apache', 658]
cert [True, '2026-02-09', 'www.vdrp.icdfa.edu.ng', ['TLS 1.2', 'TLS 1.3']]

```



```

www.payment.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://www.payment.icdfa.edu.ng/', 'Apache', 281]
https [403, None, 'Apache', 358]
cert [True, '2026-02-21', 'www.payment.icdfa.edu.ng', ['TLS 1.2', 'TLS 1.3']]

www.pcep.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://www.pcep.icdfa.edu.ng/', 'Apache', 278]
https [200, None, 'Apache', 10319]
cert [True, '2026-02-01', 'www.pcep.icdfa.edu.ng', ['TLS 1.2']]

www.cybersmart.icdfa.edu.ng ['131.153.147.186']
http [None, None, None, None]
https [403, None, 'Apache', 358]
cert [True, '2026-02-11', 'cybersmart.icdfa.edu.ng', ['TLS 1.2', 'TLS 1.3']]

www.ijcf.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://www.ijcf.icdfa.edu.ng/', 'Apache', 278]
https [400, None, 'Apache', 24]
cert [True, '2026-03-17', 'www.ijcf.icdfa.edu.ng', ['TLS 1.2', 'TLS 1.3']]

pcep.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://pcep.icdfa.edu.ng/', 'Apache', 274]
https [200, None, 'Apache', 10319]
cert [True, '2026-02-01', 'www.pcep.icdfa.edu.ng', ['TLS 1.2', 'TLS 1.3']]

caps.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://caps.icdfa.edu.ng/', 'Apache', 274]
https [200, None, 'Apache', 18904]
cert [True, '2026-02-21', 'www.caps.icdfa.edu.ng', ['TLS 1.2']]

intranet.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://intranet.icdfa.edu.ng/', 'Apache', 278]
https [200, None, 'Apache', 482]
cert [True, '2026-01-23', 'www.intranet.icdfa.edu.ng', ['TLS 1.3']]

orientation.icdfa.edu.ng ['131.153.147.186']
http [None, None, None, None]
https [200, None, 'Apache', 18392]
cert [True, '2026-01-25', 'orientation.icdfa.edu.ng', ['TLS 1.2', 'TLS 1.3']]

www.caps.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://www.caps.icdfa.edu.ng/', 'Apache', 278]
https [200, None, 'Apache', 18904]
cert [True, '2026-02-21', 'www.caps.icdfa.edu.ng', ['TLS 1.2', 'TLS 1.3']]

www.rc.icdfa.edu.ng ['131.153.147.186']
http [None, None, None, None]
https [403, None, 'Apache', 358]
cert [True, '2026-02-19', '*.icdfa.edu.ng', ['TLS 1.3']]

cybersmart.icdfa.edu.ng ['131.153.147.186']
http [301, 'https://cybersmart.icdfa.edu.ng/', 'Apache', 280]
https [200, None, 'Apache', 23224]
cert [True, '2026-02-11', 'cybersmart.icdfa.edu.ng', ['TLS 1.2']]

28 domains in 00:00:27

```

Figure 9: Output of Knockpy enumeration for icdfa.edu.ng

```
Session Actions Edit View Help
(knock-env)~(ladesha@kali)~(~/knock)
$ knockpy -d nasarawastate.gov.ng --recon
Reconnaissance ...
- VirusTotal: X
- Shodan: X
Scanned 51/51 domains ...

mtii.nasarawastate.gov.ng ['181.215.243.156']
http [None, None, None, None]
https [None, None, None, None]
cert [None, None, None, None]

mwasd.nasarawastate.gov.ng ['181.215.243.156']
http [None, None, None, None]
https [None, None, None, None]
cert [None, None, None, None]

www.siwes.nasarawastate.gov.ng ['181.215.243.156']
http [302, '/portal/', 'Apache', 0]
https [None, None, None, None]
cert [None, None, None, None]

www.naepd.nasarawastate.gov.ng ['181.215.243.156']
http [200, None, 'Apache', 0]
https [None, None, None, None]
cert [None, None, None, None]

www.health.nasarawastate.gov.ng ['181.215.243.156']
http [403, None, 'Apache', 358]
https [None, None, None, None]
cert [None, None, None, None]

www.mtii.nasarawastate.gov.ng ['181.215.243.156']
http [403, None, 'Apache', 358]
https [None, None, None, None]
cert [None, None, None, None]

nasema.nasarawastate.gov.ng ['181.215.243.156']
http [None, None, None, None]
https [None, None, None, None]
cert [None, None, None, None]

www.dms.nasarawastate.gov.ng ['181.215.243.156']
http [302, 'admin/', 'Apache', 0]
https [None, None, None, None]
cert [None, None, None, None]

www.nscsc.nasarawastate.gov.ng ['181.215.243.156']
http [None, None, None, None]
https [None, None, None, None]
cert [None, None, None, None]

www.finance.nasarawastate.gov.ng ['181.215.243.156']
http [None, None, None, None]
https [None, None, None, None]
cert [None, None, None, None]

naepa.nasarawastate.gov.ng ['181.215.243.156']
http [None, None, None, None]
https [None, None, None, None]
```

```
Session Actions Edit View Help
(knock-env)ladesha@kali: ~/knock

ssg.nasarawastate.gov.ng ['181.215.243.156']
http [None, None, None, None]
https [None, None, None, None]
cert [None, None, None, None]

www.asset.nasarawastate.gov.ng ['181.215.243.156']
http [None, None, None, None]
https [None, None, None, None]
cert [None, None, None, None]

www.nasema.nasarawastate.gov.ng ['181.215.243.156']
http [None, None, None, None]
https [None, None, None, None]
cert [None, None, None, None]

www.mwasd.nasarawastate.gov.ng ['181.215.243.156']
http [None, None, None, None]
https [None, None, None, None]
cert [None, None, None, None]

hcd.nasarawastate.gov.ng ['181.215.243.156']
http [301, 'https://nashcd.com.ng/', 'Apache', 270]
https [301, 'https://nashcd.com.ng/', 'Apache', 270]
cert [True, '2026-02-03', 'www.mtii.nasarawastate.gov.ng', ['TLS 1.2', 'TLS 1.3']]

www.bpp.nasarawastate.gov.ng ['181.215.243.156']
http [None, None, None, None]
https [None, None, None, None]
cert [None, None, None, None]

siwes.nasarawastate.gov.ng ['181.215.243.156']
http [None, None, None, None]
https [302, '/portal/', 'Apache', 0]
cert [True, '2026-02-28', 'www.siwes.nasarawastate.gov.ng', ['TLS 1.2', 'TLS 1.3']]

www.ocds.nasarawastate.gov.ng ['181.215.243.156']
http [None, None, None, None]
https [None, None, None, None]
cert [None, None, None, None]

nasarawastate.gov.ng ['181.215.243.156']
http [301, 'https://nasarawastate.gov.ng/', 'Apache', 277]
https [None, None, None, None]
cert [None, None, None, None]

dms.nasarawastate.gov.ng ['181.215.243.156']
http [None, None, None, None]
https [302, 'admin/', 'Apache', 0]
cert [True, '2026-02-04', 'www.dms.nasarawastate.gov.ng', ['TLS 1.2', 'TLS 1.3']]

www.csc.nasarawastate.gov.ng ['181.215.243.156']
http [301, 'https://nasarawacsc.com.ng/', 'Apache', 275]
https [301, 'https://nasarawacsc.com.ng/', 'Apache', 275]
cert [False, '2025-05-16', 'csc.nasarawastate.gov.ng', ['TLS 1.2', 'TLS 1.3']]

health.nasarawastate.gov.ng ['181.215.243.156']
http [403, None, 'Apache', 358]
https [403, None, 'Apache', 358]
cert [True, '2026-02-03', 'www.mtii.nasarawastate.gov.ng', ['TLS 1.2', 'TLS 1.3']]
```

```

www.csc.nasarawastate.gov.ng ['181.215.243.156']
http [301, 'https://nasarawacsc.com.ng/', 'Apache', 275]
https [301, 'https://nasarawacsc.com.ng/', 'Apache', 275]
cert [False, '2025-05-16', 'csc.nasarawastate.gov.ng', ['TLS 1.2', 'TLS 1.3']]

health.nasarawastate.gov.ng ['181.215.243.156']
http [403, None, 'Apache', 358]
https [403, None, 'Apache', 358]
cert [True, '2026-02-03', 'www.mtii.nasarawastate.gov.ng', ['TLS 1.2', 'TLS 1.3']]

www.hcd.nasarawastate.gov.ng ['181.215.243.156']
http [301, 'https://nashcd.com.ng/', 'Apache', 270]
https [301, 'https://nashcd.com.ng/', 'Apache', 270]
cert [True, '2026-02-03', 'www.mtii.nasarawastate.gov.ng', ['TLS 1.2', 'TLS 1.3']]

www.ssg.nasarawastate.gov.ng ['181.215.243.156']
http [None, None, None, None]
https [301, 'https://ssg.nasarawastate.gov.ng/', 'Apache', 0]
cert [True, '2026-03-19', 'ssg.nasarawastate.gov.ng', ['TLS 1.2', 'TLS 1.3']]

www.sgs.nasarawastate.gov.ng ['181.215.243.156']
http [403, None, 'Apache', 358]
https [403, None, 'Apache', 358]
cert [True, '2026-01-29', 'sgs.nasarawastate.gov.ng', ['TLS 1.2', 'TLS 1.3']]

pension.nasarawastate.gov.ng ['181.215.243.156']
http [302, 'login.php', 'Apache', 55987]
https [302, 'login.php', 'Apache', 55987]
cert [True, '2026-02-04', 'www.pension.nasarawastate.gov.ng', ['TLS 1.2', 'TLS 1.3']]

cpcontacts.nasarawastate.gov.ng ['181.215.243.156']
http [None, None, None, None]
https [401, None, 'cPanel', 36]
cert [True, '2026-01-21', 'nasarawastate.gov.ng', ['TLS 1.2', 'TLS 1.3']]

csc.nasarawastate.gov.ng ['181.215.243.156']
http [301, 'https://nasarawacsc.com.ng/', 'Apache', 275]
https [301, 'https://nasarawacsc.com.ng/', 'Apache', 275]
cert [False, '2025-05-16', 'csc.nasarawastate.gov.ng', ['TLS 1.2', 'TLS 1.3']]

www.pension.nasarawastate.gov.ng ['181.215.243.156']
http [302, 'login.php', 'Apache', 55987]
https [302, 'login.php', 'Apache', 55987]
cert [True, '2026-02-04', 'www.pension.nasarawastate.gov.ng', ['TLS 1.3']]

cpcalendar.nasarawastate.gov.ng ['181.215.243.156']
http [None, None, None, None]
https [401, None, 'cPanel', 36]
cert [True, '2026-01-21', 'nasarawastate.gov.ng', ['TLS 1.2', 'TLS 1.3']]

bnp.nasarawastate.gov.ng ['181.215.243.156']
http [None, None, None, None]
https [500, None, 'Apache', 2634]
cert [True, '2026-02-14', 'www.bnp.nasarawastate.gov.ng', ['TLS 1.2', 'TLS 1.3']]

32 domains in 00:00:53

```

Figure 10: Results of Knockpy enumeration for nasarawastate.gov.ng

```

(knock-env)-(ladesha@kali)-[~/knock]
$ knockpy -d icdfa.org.ng --recon
Reconnaissance ...
- VirusTotal: ✗
- Shodan: ✗

icdfa.org.ng ['131.153.147.186']
http [301, 'https://icdfa.org.ng/', 'Apache', 269]
https [302, 'https://icdfa.edu.ng', 'Apache', 0]
cert [True, '2026-02-27', '*.icdfa.edu.ng', ['TLS 1.2', 'TLS 1.3']]

1 domains in 00:00:10

```

Figure 11: Output of Knockpy results for icdfa.org.ng

4.3: Comparative Analysis – Sublist3r vs KnockPy

DOMAINS	SUBLIST3R	KNOCKPY
ICDFA.EDU.NG	✓ Total subdomains:30 ✓ Discovered subdomains:30	➤ Total subdomains:28 ➤ Discovered subdomains:28
NASARAWASTATE.GOV.NG	✓ Total subdomains:108 ✓ Discovered subdomains:108	➤ Total subdomains:51 ➤ Discovered subdomains:32
ICDFA.ORG.NG	✓ Total subdomains:1	➤ Total subdomains:1

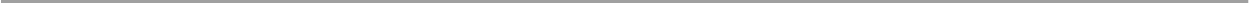
	✓ Discovered subdomains:1	➤ Discovered subdomains:1
--	---------------------------	---------------------------

Table 5:Comparative Analysis of Sublist3r and KnockPy

Tool Methodology Comparison:

<i>Aspect</i>	<i>Sublist3r</i>	<i>KnockPy</i>
<i>Data Sources</i>	Search engines, SSL certificates, VirusTotal, ThreatCrowd	DNS brute forcing, wordlist-based
<i>Approach</i>	Passive OSINT gathering	Active DNS querying
<i>Speed</i>	Generally faster	Can be slower with large wordlists
<i>Accuracy</i>	High for indexed subdomains	High for DNS-configured subdomains
<i>Stealth</i>	More stealthy (passive)	More detectable (active queries)

Table 6:Difference between Sublist3r and KnockPy



Part 5: Directory Enumeration with Dirb

5.1: Basic Dirb Scan

Commands Used:

dirb http://192.168.0.105

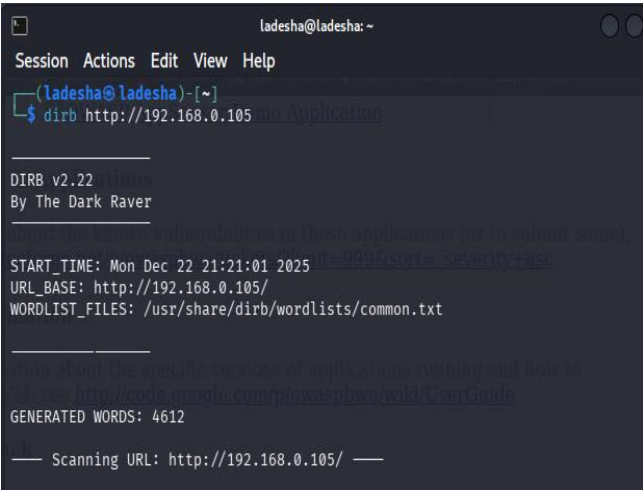


Figure 12:Dirb scan in progress

```

+ http://192.168.0.105/.bash_history (CODE:200|SIZE:302)
=> DIRECTORY: http://192.168.0.105/assets/
=> DIRECTORY: http://192.168.0.105/cgi-bin/
+ http://192.168.0.105/cgi-bin/ (CODE:200|SIZE:1070)
+ http://192.168.0.105/crossdomain (CODE:200|SIZE:200)
+ http://192.168.0.105/crossdomain.xml (CODE:200|SIZE:200)
=> DIRECTORY: http://192.168.0.105/evil/
+ http://192.168.0.105/favicon.ico (CODE:200|SIZE:3638)
=> DIRECTORY: http://192.168.0.105/gallery2/
=> DIRECTORY: http://192.168.0.105/icon/
=> DIRECTORY: http://192.168.0.105/images/
+ http://192.168.0.105/index (CODE:200|SIZE:1227)
+ http://192.168.0.105/index.html (CODE:200|SIZE:28067)
=> DIRECTORY: http://192.168.0.105/javascript/
=> DIRECTORY: http://192.168.0.105/joomla/
=> DIRECTORY: http://192.168.0.105/phpBB2/
=> DIRECTORY: http://192.168.0.105/phpmyadmin/
+ http://192.168.0.105/server-status (CODE:403|SIZE:215)
=> DIRECTORY: http://192.168.0.105/test/
=> DIRECTORY: http://192.168.0.105/wordpress/

— Entering directory: http://192.168.0.105/assets/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://192.168.0.105/cgi-bin/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

```

Figure 13: Discovered directories and files

Discovered Directories and Files:

Here are some of the identified directories and files where status code 200 means successful and status code 500 means internal server error and 302 is a temporary redirection message

<i>PATH</i>	<i>STATUS CODE</i>	<i>SIZE</i>	<i>TYPE</i>
<i>/.bash_history</i>	200	302	File
<i>/assets/</i>	200	-	Directory
<i>/cgi-bin/</i>	200	1070	Directory
<i>/crossdomain</i>	200	200	File
<i>/crossdomain.xml</i>	200	200	File
<i>/evil/</i>	200	-	Directory
<i>/favicon.ico</i>	200	3638	File
<i>/gallery2/</i>	200	-	Directory
<i>/gallery2/config</i>	500	0	File
<i>/gallery2/images/</i>	200	-	Directory
<i>/gallery2/index</i>	302	0	File
<i>/gallery2/index.php</i>	302	0	File

<i>/gallery2/LICENSE</i>	200	18011	File
<i>/gallery2/login</i>	200	33	File
<i>/gallery2/main</i>	200	5887	File
<i>/gallery2/modules/</i>	200	-	Directory
<i>/gallery2/README</i>	200	73808	File
<i>/index</i>	200	1227	File
<i>/index.html</i>	200	28067	File
<i>/javascript/</i>	200	-	Directory
<i>/javascript/jquery/</i>	200	-	Directory
<i>/joomla/</i>	200	-	Directory
<i>/joomla/administrator/</i>	200	-	Directory
<i>/joomla/cache/</i>	200	-	Directory
<i>/joomla/components/</i>	200	-	Directory
<i>/joomla/configuration</i>	200	0	File

Part 6: Port Scanning and Vulnerability Detection

6.1: Nmap Port Scanning

Basic Scan:

nmap 192.168.0.105

nmap -sV -O 192.168.0.105

nmap --script vuln 192.168.0.105

```
ladesha@ladesha:~$
Session Actions Edit View Help

zsh: corrupt history file /home/ladesha/.zsh_history
(ladesha@ladesha)~$
$ nmap 192.168.0.105
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-23 15:02 EAT
Nmap scan report for 192.168.0.105
Host is up (0.00018s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
139/tcp   open  netbios-ssn
143/tcp   open  imap
443/tcp   open  https
445/tcp   open  microsoft-ds
5001/tcp  open  complex-link
8080/tcp  open  http-proxy
8081/tcp  open  blackice-cap
MAC Address: 08:00:27:05:C9:08 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)

Nmap done: 1 IP address (1 host up) scanned in 0.55 seconds

(ladesha@ladesha)~$
```

```
(ladesha@ladesha)~$
$ nmap -sV 0 192.168.0.105
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-23 15:05 EAT
Nmap scan report for 0 (0.0.0.0)
Host is up.
RDNS record for 0.0.0.0: pl.hole
All 1000 scanned ports on 0 (0.0.0.0) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 192.168.0.105
Host is up (0.00013s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 5.3p1 Debian 3ubuntu4 (Ubuntu Linux; proto
col 2.0)
80/tcp    open  http         Apache httpd 2.2.14 ((Ubuntu) mod_mono/2.4.3 PHP/5
.3.2-Iubuntu4.38 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/
2.6.5 mod_ssl/2.2.14 OpenSSL ...)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
143/tcp   open  imap         Courier Imapd (released 2000)
443/tcp   open  ssl/http     Apache httpd 2.2.14 ((Ubuntu) mod_mono/2.4.3 PHP/5
.3.2-Iubuntu4.38 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/
2.6.5 mod_ssl/2.2.14 OpenSSL ...)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
5001/tcp  open  java-object  Java Object Serialization
8080/tcp  open  http         Apache/omcat/Coyote JSP engine 1.1
8081/tcp  open  http         Jetty 6.1.25
1 service unrecognized despite returning data. If you know the service/versio
n, please submit the following fingerprint at https://nmap.org/cgi-bin/submit
.cgi?new-service :
SF-Port001-TCP:V=7.95NI=7MD=12/23Time=694A8684XP=x86_64-pc-linux-gnuR(N
SF:ULL:4,"xac\xed\x85");
MAC Address: 08:00:27:05:C9:08 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://n
map.org/submit/.
Nmap done: 2 IP addresses (2 hosts up) scanned in 231.53 seconds
```

```
(ladesha@ladesha)~$
$ nmap --script vuln 192.168.0.105
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-23 15:10 EAT
Pre-scan script results:
|_ broadcast-avahi-dos:
|_ Discovered hosts:
|_ 224.0.0.251
|_ After NULL UDP avahi packet DoS (CVE-2011-1002).
|_ Hosts are all up (not vulnerable).
Nmap scan report for 192.168.0.105
Host is up (0.00026s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
|_ http-enum:
|_ /wordpress/: Blog
|_ /test/: Test page
|_ /mono/: Mono
|_ /crossdomain.xml: Adobe Flash crossdomain policy
|_ /phpmyadmin/: phpMyAdmin
|_ /wordpress/wp-login.php: Wordpress login page.
|_ /cgi-bin/: Potentially interesting folder w/ directory listing
|_ /icons/: Potentially interesting folder w/ directory listing
|_ /images/: Potentially interesting folder w/ directory listing
|_ http-vuln-cve2011-3192:
|_ VULNERABLE:
|_ Apache byterange filter DoS
|_ State: VULNERABLE
|_ IDs: BID:49303 CVE:CVE-2011-3192
|_ The Apache web server is vulnerable to a denial of service attack whe
n numerous
|_ overlapping byte ranges are requested.
|_ Disclosure date: 2011-08-19
|_ References:
|_ https://seclists.org/fulldisclosure/2011/Aug/175
|_ https://www.tenable.com/plugins/nessus/55976
|_ https://www.securityfocus.com/bid/49303
|_ https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-3192
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-cookie-flags:
|_ /mono/:
|_ ASP.NET SessionId:
|_ httponly flag not set
|_ http-csrf: Couldn't find any CSRF vulnerabilities.
|_ http-internal-ip-disclosure:
|_ Internal IP Leaked: 127.0.1.1
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-trace: TRACE is enabled
|_ http-cross-domain-policy:
|_ VULNERABLE:
```

```
ladesha@ladesha:~$
Session Actions Edit View Help

|_ http-cross-domain-policy:
|_ VULNERABLE:
|_ Cross-domain and Client Access policies.
|_ State: VULNERABLE
|_ A cross-domain policy file specifies the permissions that a web client
such as Java, Adobe Flash, Adobe Reader,
|_ etc. use to access data across different domains. A client acces poli
cy file is similar to cross-domain policy
|_ but is used for MS Silverlight applications. Overly permissive config
urations enables Cross-site Request
|_ Forgery attacks, and may allow third parties to access sensitive data
meant for the user.
|_ Check results:
|_ /crossdomain.xml:
|_ <?xml version="1.0"?>
|_ <!DOCTYPE cross-domain-policy SYSTEM "http://www.macromedia.com/xml
/dtds/cross-domain-policy.dtd">
|_ <cross-domain-policy>
|_ <allow-access-from domain="*" />
|_ </cross-domain-policy>
|_ Extra information:
|_ Trusted domains:*
|_ References:
|_ https://www.adobe.com/devnet-docs/acrobatetk/tools/AppSec/CrossDomain
_PolicyFile_Specification.pdf
|_ http://sethsec.blogspot.com/2014/03/exploiting-misconfigured-crossdom
ain.html
|_ https://www.owasp.org/index.php/Test_RIA_cross_domain_policy_X200TG-C
ONFIG-008X29
|_ http://gursevkalra.blogspot.com/2013/08/bypassing-same-origin-policy-
with-flash.html
|_ http://acunetix.com/vulnerabilities/web/insecure-clientaccesspolicy-x
ml-file
|_ https://www.adobe.com/devnet/articles/crossdomain_policy_file_spec.ht
ml
139/tcp   open  netbios-ssn
143/tcp   open  imap
443/tcp   open  https
|_ http-cross-domain-policy:
|_ VULNERABLE:
|_ Cross-domain and Client Access policies.
|_ State: VULNERABLE
|_ A cross-domain policy file specifies the permissions that a web client
such as Java, Adobe Flash, Adobe Reader,
|_ etc. use to access data across different domains. A client acces poli
cy file is similar to cross-domain policy
|_ but is used for MS Silverlight applications. Overly permissive config
urations enables Cross-site Request
|_ Forgery attacks, and may allow third parties to access sensitive data
meant for the user.
|_ Check results:
|_ /crossdomain.xml:
```

```

...
the target web server and sending a partial request. By doing so, it
starves
the http server's resources causing Denial Of Service.
|
| Disclosure date: 2009-09-17
| References:
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
| http://ha.ckers.org/slowloris/
| http-cookie-flags:
| /manager/html/upload:
| JSESSIONID:
| httponly flag not set
| /manager/html:
| JSESSIONID:
| httponly flag not set
| http-enum:
| /examples/: Sample scripts
| /manager/html/upload: Apache Tomcat (401 Unauthorized)
| /manager/html: Apache Tomcat (401 Unauthorized)
| /docs/: Potentially interesting folder
8081/tcp open blackice-icecap
MAC Address: 08:00:27:D5:C9:08 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)

Host script results:
|_smb-vuln-cve-2012-1182: Could not negotiate a connection:SMB: ERROR: Serv
er returned less data than it was supposed to (one or more fields are missing
); aborting [14]
|_smb-vuln-ms10-054: false
|_smb-vuln-regsvcs-dos:
| VULNERABLE:
| Service regsvcs in Microsoft Windows systems vulnerable to denial of servi
ce
| State: VULNERABLE
| The service regsvcs in Microsoft Windows 2000 systems is vulnerable to
denial of service caused by a null deference
| pointer. This script will crash the service if it is vulnerable. This
vulnerability was discovered by Ron Bowes
| while working on smb-enum-sessions.
|
|_smb-vuln-ms10-061: Could not negotiate a connection:SMB: ERROR: Server retu
rned less data than it was supposed to (one or more fields are missing); abor
ting [14]

Nmap done: 1 IP address (1 host up) scanned in 119.77 seconds

```

Figure 14: Screenshots of basic and comprehensive Nmap results

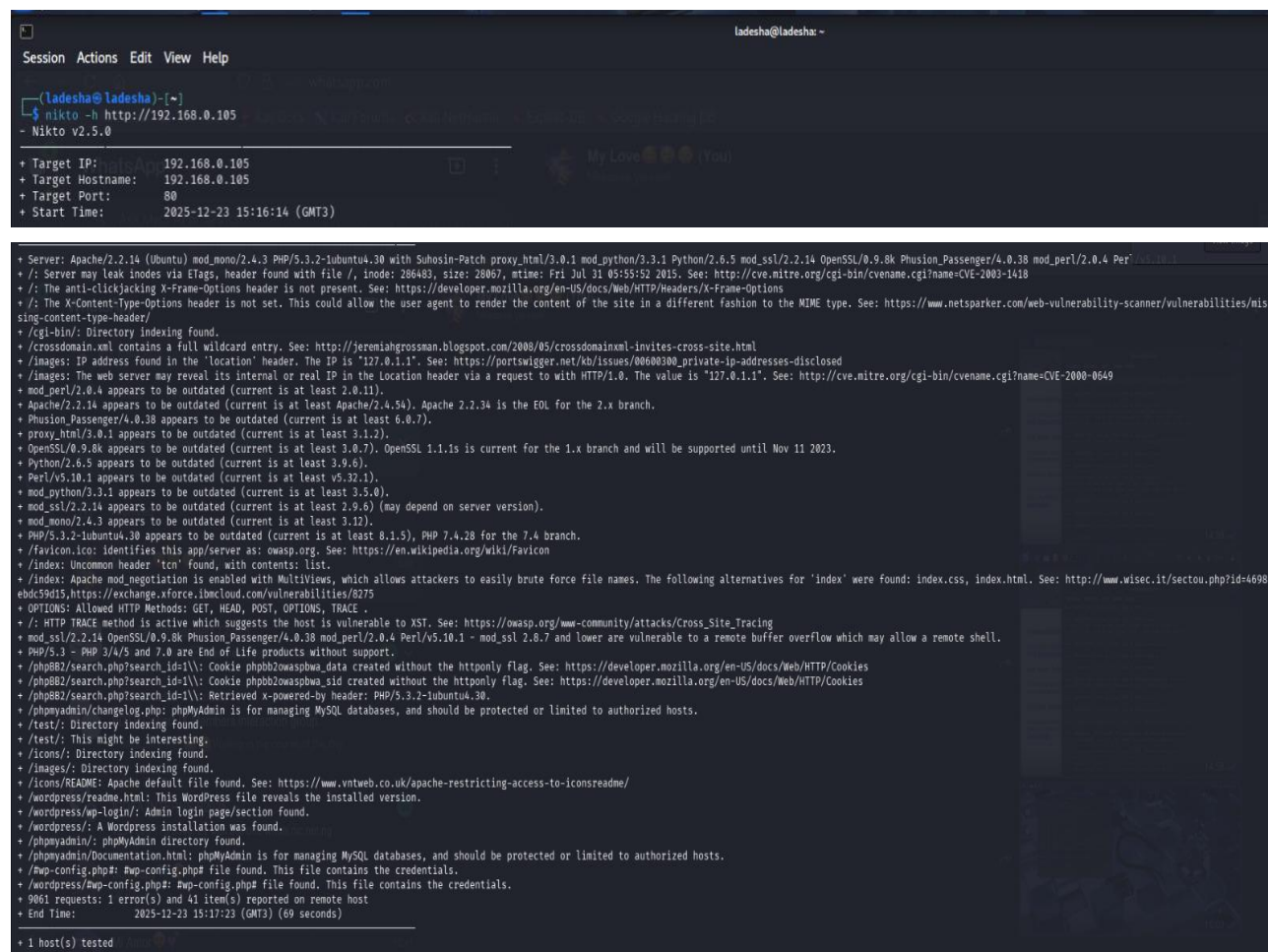
PORT	STATE	SERVICE	ADDITIONAL INFO
22	Open	SSH	Standard SSH service for remote access
80	Open	HTTP	Web server with multiple modules including PHP, Python, and SSL support
139	Open	netbios-ssn	NetBIOS session service for file/printer sharing
143	Open	IMAP	Email retrieval service
443	Open	HTTPS/SSL	Secure web server (same as port 80 but encrypted)
445	Open	microsoft-ds	SMB/CIFS file sharing service
5001	Open	java-object	Java RMI or serialization service
8080	Open	HTTP	Alternative web server, typically for Java applications
8081	Open	HTTP	Java-based web server

Table 7: Open ports and running services discovered by Nmap

6.2: Vulnerability Scanning with Nikto

Commands Used:

nikto -h http://192.168.0.105



```
ladesha@ladesha: ~  
Session Actions Edit View Help  
[ladesha@ladesha:~]$ nikto -h http://192.168.0.105  
- Nikto v2.5.0  
  
+ Target IP: 192.168.0.105  
+ Target Hostname: 192.168.0.105  
+ Target Port: 80  
+ Start Time: 2025-12-23 15:16:14 (GMT3)  
  
+ Server: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/5.10.1  
+ /: Server may leak inodes via ETags, header found with file /, inode: 286483, size: 28067, mtime: Fri Jul 31 05:55:52 2015. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/mis-sing-content-type-header/  
+ /cgi-bin/: Directory indexing found.  
+ /crossdomain.xml contains a full wildcard entry. See: http://jeremiahgrossman.blogspot.com/2008/05/crossdomainxml-invites-cross-site.html  
+ /images: IP address found in the 'location' header. The IP is '127.0.1.1'. See: https://portswigger.net/kb/issues/00600300_private-ip-addresses-disclosed  
+ /images: The web server may reveal its internal or real IP in the location header via a request to with HTTP/1.0. The value is '127.0.1.1'. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-0649  
+ mod_perl/2.0.4 appears to be outdated (current is at least 2.0.11).  
+ Apache/2.2.14 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.  
+ Phusion_Passenger/4.0.38 appears to be outdated (current is at least 6.0.7).  
+ proxy_html/3.0.1 appears to be outdated (current is at least 3.1.2).  
+ OpenSSL/0.9.8k appears to be outdated (current is at least 3.0.7). OpenSSL 1.1.1s is current for the 1.x branch and will be supported until Nov 11 2023.  
+ Python/2.6.5 appears to be outdated (current is at least 3.9.6).  
+ Perl/5.10.1 appears to be outdated (current is at least v5.32.1).  
+ mod_python/3.3.1 appears to be outdated (current is at least 3.5.0).  
+ mod_ssl/2.2.14 appears to be outdated (current is at least 2.9.6) (may depend on server version).  
+ mod_mono/2.4.3 appears to be outdated (current is at least 3.12).  
+ PHP/5.3.2-1ubuntu4.30 appears to be outdated (current is at least 8.1.5), PHP 7.4.28 for the 7.4 branch.  
+ /favicon.ico: Identifies this app/server as: owasp.org. See: https://en.wikipedia.org/wiki/Favicon  
+ /index: Unknown header 'ten' found, with contents: List.  
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.css, index.html. See: http://www.wisec.it/sectou.php?id=4698  
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE .  
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing  
+ mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/5.10.1 - mod_ssl 2.8.7 and lower are vulnerable to a remote buffer overflow which may allow a remote shell.  
+ PHP/5.3 - PHP 3/4/5 and 7.0 are End of Life products without support.  
+ /phpBB2/search.php?search_id=1: Cookie phpb2owaspbwa_sid created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies  
+ /phpBB2/search.php?search_id=1: Retrieved x-powered-by header: PHP/5.3.2-1ubuntu4.30.  
+ /phpmyadmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.  
+ /test/: Directory indexing found.  
+ /test/: This might be interesting.  
+ /icons/: Directory indexing found.  
+ /images/: Directory indexing found.  
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/  
+ /wordpress/readme.html: This WordPress file reveals the installed version.  
+ /wordpress/wp-login/: Admin login page/section found.  
+ /wordpress/: A Wordpress installation was found.  
+ /phpmyadmin/: phpMyAdmin directory found.  
+ /phpmyadmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.  
+ /wp-config.php: #wp-config.php# file found. This file contains the credentials.  
+ /wordpress/wp-config.php: #wp-config.php# file found. This file contains the credentials.  
+ 9061 requests: 1 error(s) and 41 item(s) reported on remote host  
+ End Time: 2025-12-23 15:17:23 (GMT3) (69 seconds)  
  
+ 1 host(s) tested
```

Figure 15:Nikto scan execution results

Vulnerability	Source	Severity	CVE/OSVDB	Description
Apache Byte Range Filter DoS	Nmap	Critical	CVE-2011-3192	Apache vulnerable to denial of service via overlapping byte ranges
mod_ssl Buffer Overflow	Nikto	Critical	-	mod_ssl 2.2.14 vulnerable to remote buffer overflow allowing remote shell
wp-config.php Backup Exposed	Nikto	Critical	-	fwp-config.php# file contains database credentials
Outdated Apache Server	Nikto	High	-	Apache 2.2.14 (EOL, current is 2.4.54+)
Outdated PHP Version	Nikto	High	-	PHP 5.3.2 - End of Life, no security updates
Outdated OpenSSL	Nikto	High	-	OpenSSL 0.9.8k (EOL, current is 3.0.7+)

<i>SQL Injection Vulnerabilities</i>	Nmap	High	-	Multiple injection points in multillidae, WackoPicko, phpBB2, gallery2, WordPress
<i>Wildcard Cross-Domain Policy</i>	Nikto/Nmap	High	-	/crossdomain.xml allows unrestricted access from any domain
<i>HTTP TRACE Method Enabled</i>	Nikto/Nmap	High	-	Vulnerable to XST (Cross-Site Tracing) attacks
<i>Apache MultiViews Brute Force</i>	Nikto	High	-	mod_negotiation with MultiViews allows easy file name brute forcing
<i>Insecure HTTP Methods</i>	Nikto	High	-	OPTIONS and TRACE methods enabled
<i>phpMyAdmin Exposed</i>	Nikto/Nmap	High	-	Database management interface accessible without protection
<i>Missing Anti-Clickjacking Header</i>	Nikto	Medium	-	X-Frame-Options header not present
<i>Missing X-Content-Type-Options</i>	Nikto	Medium	-	MIME type sniffing protection not enabled
<i>CGI Directory Indexing</i>	Nikto	Medium	-	/cgi-bin/ directory contents exposed
<i>Internal IP Disclosure</i>	Nikto/Nmap	Medium	CVE-2000-0649	Location header reveals internal IP (127.0.0.1)
<i>Outdated mod_perl</i>	Nikto	Medium	-	mod_perl 2.0.4 (current is 2.0.11+)
<i>Outdated Phusion Passenger</i>	Nikto	Medium	-	Phusion_Passenger 4.0.38 (current is 6.0.7+)
<i>Outdated Python</i>	Nikto	Medium	-	Python 2.6.5 (current is 3.9.6+)
<i>Outdated Perl</i>	Nikto	Medium	-	Perl 5.10.1 (current is 5.32.1+)
<i>Outdated mod_python</i>	Nikto	Medium	-	mod_python 3.3.1 (current is 3.5.0+)
<i>Outdated mod_ssl</i>	Nikto	Medium	-	mod_ssl 2.2.14 (current is 2.9.6+)
<i>Weak Diffie-Hellman Key Exchange</i>	Nmap	Medium	-	1024-bit MODP group susceptible to passive eavesdropping
<i>CSRF Vulnerabilities</i>	Nmap	Medium	-	Multiple applications vulnerable to Cross-Site Request Forgery
<i>phpBB Cookies Without httponly</i>	Nikto	Medium	-	phpbb2owaspbwa_data and phpbb2owaspbwa_sid cookies lack httponly flag
<i>WordPress Installation Exposed</i>	Nikto	Medium	-	WordPress readme.html reveals version, wp-login accessible
<i>phpMyAdmin Documentation Exposed</i>	Nikto	Medium	-	Documentation.html accessible publicly
<i>Test Directory Found</i>	Nikto	Medium	-	/test/ directory with indexing enabled
<i>ETag Information Disclosure</i>	Nikto	Low	-	Server leaks inode information via ETags
<i>Outdated proxy_html Module</i>	Nikto	Low	-	proxy_html 3.0.1 (current is 3.1.2+)
<i>Outdated mod_mono</i>	Nikto	Low	-	mod_mono 2.4.3 (current is 3.12+)
<i>favicon.ico Disclosure</i>	Nikto	Low	-	Identifies server as owasp.org
<i>Uncommon 'tcn' Header</i>	Nikto	Low	-	Apache mod_negotiation header present

<i>phpBB X-Powered-By Header</i> <i>Directory Indexing</i> <i>Apache Icons/README Exposed</i>	Nikto	Low	-	Reveals PHP version in headers
	Nikto/Nmap	Low	-	Enabled in /icons/, /images/, multiple directories
	Nikto	Low	-	Default Apache files accessible

Table 8: Identified vulnerabilities by Nikto and Namp tools

Part 7: Bash Scripting - Reconnaissance Automation Tool

7.1: Script Purpose

Create an automated reconnaissance tool that allows users to select and execute different scanning tools against a target IP address or domain.

7.2: Script Implementation

Script Code:

```

Session Actions Edit View Help
GNU nano 8.7 automatic_tool.sh
#!/bin/bash

simple_automatic_tool(){
    echo "===== "
    echo "RECONNAISSANCE AUTOMATION TOOL"
    echo "===== "

    read -p "Enter your target IP address: " target
    echo " "

    echo "=== Tool Selection ==="
    echo "1. Whatweb - Web technology detection"
    echo "2. Nmap - Port scanning"
    echo "3. Dirb - Directory bruteforcing"
    echo "4. KnockPy - Subdomain enumeration"
    read -p "Choose an option (1-4): " tool
    echo " "

    if [ -z "$target" ]; then
        echo "Error: Target cannot be empty!"
        return 1
    fi

    if [ "$tool" -eq 1 ]; then
        echo "----- Output from WHATWEB tool you selected: -----"
        whatweb "$target"

    elif [ "$tool" -eq 2 ]; then
        echo "----- Output from NMAP tool you selected: -----"
        nmap "$target"
        echo "----- - - - - AGGRESSIVE NMAP - - - - -"
        nmap -sV -o "$target"

    elif [ "$tool" -eq 3 ]; then
        echo "----- Output from DIRB tool you selected: -----"
        dirb "http://$target"

    elif [ "$tool" -eq 4 ]; then
        echo "----- Output from KNOCKPY tool you selected: -----"
        knockpy -d "$target"

    fi
}

simple_automatic_tool

```

Figure 16: Screenshot of complete bash script code

Making Script Executable: `chmod +x automatic_tool.sh`

Test Case 1: WhatWeb Execution

`./recon_tool.sh`

```
(Ladesha@kali)-[~]
└─$ ./automatic_tool.sh
-----
RECONNAISSANCE AUTOMATION TOOL
-----

Enter your target IP address: google.com

== Tool Selection ==
1. Whatweb - Web technology detection
2. Nmap - Port scanning
3. Dirb - Directory bruteforcing
4. KnockPy - Subdomain enumeration
Choose an option (1-4): 1

-----Output from WHATWEB tool you selected: -----
http://google.com [301 Moved Permanently] Country[UNITED STATES][US], HTTPServer[gws], IP[172.217.170.174], RedirectLocation[http://www.google.com/], Title[301 Moved], UncommonHeaders[content-security-policy-report-only], X-Frame-Options[SAMEORIGIN], X-XSS-Protection[0]
https://google.com [301 Moved Permanently] Country[UNITED STATES][US], HTTPServer[gws], IP[172.217.170.174], RedirectLocation[https://www.google.com/], Title[301 Moved], UncommonHeaders[content-security-policy-report-only,alt-svc], X-Frame-Options[SAMEORIGIN], X-XSS-Protection[0]
http://www.google.com/ [200 OK] Cookies[AEC,NID,_Secure-STRP], Country[UNITED STATES][US], HTML5, HTTPServer[gws], HttpOnly[AEC,NID], IP[172.217.170.196], Script, Title[Google], UncommonHeaders[content-security-policy-report-only], X-Frame-Options[SAMEORIGIN], X-XSS-Protection[0]
https://www.google.com/ [200 OK] Cookies[_Secure-BUCKET,_Secure-STRP], Country[UNITED STATES][US], HTML5, HTTPServer[gws], HttpOnly[_Secure-BUCKET], IP[172.217.170.196], Script, Title[Google], UncommonHeaders[content-security-policy-report-only,accept-ch,alt-svc], X-Frame-Options[SAMEORIGIN], X-XSS-Protection[0]
```

Figure 17: Screenshot of domain request, tool selection and Whatweb execution

Test Case 2: Nmap Execution

./recon_tool.sh

```
(Ladesha@kali)-[~]
└─$ ./automatic_tool.sh
-----
RECONNAISSANCE AUTOMATION TOOL
-----

Enter your target IP address: google.com

== Tool Selection ==
1. Whatweb - Web technology detection
2. Nmap - Port scanning
3. Dirb - Directory bruteforcing
4. KnockPy - Subdomain enumeration
Choose an option (1-4): 2

-----Output from NMAP tool you selected: -----
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-23 18:01 EAT
Nmap scan report for google.com (172.217.170.174)
Host is up (0.022s latency).
Other addresses for google.com (not scanned): 2a00:1450:401a:800::200e
rDNS record for 172.217.170.174: mba01s09-in-f14.1e100.net
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 9.69 seconds
-----AGGRESSIVE NMAP-----
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-23 18:01 EAT
Nmap scan report for google.com (172.217.170.174)
Host is up (0.024s latency).
Other addresses for google.com (not scanned): 2a00:1450:401a:800::200e
rDNS record for 172.217.170.174: mba01s09-in-f14.1e100.net
All 1000 scanned ports on google.com (172.217.170.174) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Too many fingerprints match this host to give specific OS details

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 28.91 seconds
```

Figure 18: Screenshot of Nmap execution through script

Test Case 3: Dirb Execution

./recon_tool.sh

```
(ladesha@kali)-[~]
$ ./automatic_tool.sh
-----
RECONNAISSANCE AUTOMATION TOOL
-----

Enter your target IP address: google.com

== Tool Selection ==
1. Whatweb - Web technology detection
2. Nmap - Port scanning
3. Dirb - Directory bruteforcing
4. KnockPy - Subdomain enumeration
Choose an option (1-4): 3

----- Output from DIRB tool you selected: -----

DIRB v2.22
By The Dark Raver

START_TIME: Tue Dec 23 18:04:49 2025
URL_BASE: http://google.com/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

----- Scanning URL: http://google.com/ -----
+ http://google.com/2001 (CODE:301|SIZE:224)
+ http://google.com/2002 (CODE:301|SIZE:224)
+ http://google.com/2003 (CODE:301|SIZE:224)
+ http://google.com/2004 (CODE:301|SIZE:224)
+ http://google.com/2005 (CODE:301|SIZE:224)
+ http://google.com/2006 (CODE:301|SIZE:224)
+ http://google.com/2007 (CODE:301|SIZE:224)
+ http://google.com/2008 (CODE:301|SIZE:224)
+ http://google.com/2009 (CODE:301|SIZE:224)
+ http://google.com/2010 (CODE:301|SIZE:224)
+ http://google.com/2011 (CODE:301|SIZE:224)
+ http://google.com/2012 (CODE:301|SIZE:224)
+ http://google.com/2013 (CODE:301|SIZE:224)
+ http://google.com/2014 (CODE:301|SIZE:224)
+ http://google.com/a (CODE:301|SIZE:221)
+ http://google.com/A (CODE:301|SIZE:221)
+ http://google.com/about (CODE:301|SIZE:225)
+ http://google.com/accessibility (CODE:301|SIZE:233)
+ http://google.com/account (CODE:301|SIZE:227)
+ http://google.com/accounts (CODE:302|SIZE:237)
+ http://google.com/action (CODE:301|SIZE:225)
+ http://google.com/activity (CODE:301|SIZE:0)
^C> Testing: http://google.com/admin_c
```

Figure 19: Screenshot execution of Dirb through script

Test Case 4: KnockPy Execution

./recon_tool.sh

```
(ladesha@kali)-[~]
$ nano automatic_tool.sh
(ladesha@kali)-[~]
$ ./automatic_tool.sh
-----
RECONNAISSANCE AUTOMATION TOOL
-----

Enter your target IP address: google.com

== Tool Selection ==
1. Whatweb - Web technology detection
2. Nmap - Port scanning
3. Dirb - Directory bruteforcing
4. KnockPy - Subdomain enumeration
Choose an option (1-4): 4

----- Output from KNOCKPY tool you selected: -----

google.com ['172.217.178.174']
http [301, 'http://www.google.com/', 'gws', 219]
https [301, 'https://www.google.com/', 'gws', 220]
cert [False, '2026-02-25', '*.google.com', ['TLS 1.0', 'TLS 1.1', 'TLS 1.2', 'TLS 1.3']]

1 domains in 00:00:02
```

Figure 20: Screenshot of KnockPy execution through script

Script Functionality Explanation

- Initialization - Displays "RECONNAISSANCE AUTOMATION TOOL" banner
- Input Validation - Prompts "Enter your target IP address:" and checks target is not empty (returns error if empty)
- Tool Selection - Interactive menu with 6 options:

- ✓ Whatweb (Web technology detection)
 - ✓ NMAP (Aggressive NMAP scan)
 - ✓ Dirb (Directory brute forcing)
 - ✓ Knockpy (Subdomain enumeration)
- Conditional Execution - If statement matches user selection (\$tool) and executes corresponding command with \$target variable
 - Error Handling - Validates tool selection (checks if \$tool equals 1-4), displays error for invalid choices
 - Output Management - Feedback showing selected tool and execution status (e.g., "Output from WHATWEB tool you selected: -----")
-

Part 8: POST vs GET Requests

A GET request is mainly used when I want to retrieve information from a website. For example, when I search for something on Google or click a link, I can see the data being sent directly in the browser's address bar. This means the request is visible, can be saved in browser history, and can even be shared with someone else by copying the link. Because of this visibility, I understand that GET requests are not suitable for sensitive information.

A POST request, on the other hand, is what I usually see being used when submitting forms such as logging into a website or registering an account. When I enter my username and password and click "login," the details are sent inside the request body and do not appear in the URL. Even though POST is not fully secure on its own, it reduces exposure of sensitive data compared to GET, which is why it is commonly used for authentication and data submission.

Part 9: Information Gathering in Web Application Security

Why Information Gathering is Essential:

Information gathering is the pivotal foundation of both offensive and defensive security operations. Before attacking or defending a system, you need to understand what you're dealing with. It's like surveying a building before planning its security or attempting to breach it. It enables efficient identification of potential weakness, proper mapping of the network architecture and understanding of the technology stack thus providing comprehensive understanding for both the attacker and defender of the system.

For Attackers (Penetration Testers): Information gathering helps identify the attack surface. By discovering open ports, running services, web technologies, and subdomains, penetration testers can identify potential exploits. Finding outdated software versions reveals known vulnerabilities that can be exploited. Discovering hidden directories might expose administrative

interfaces or backup files. The more information gathered, the more targeted and efficient the attack can be, rather than blindly trying exploits that won't work.

For Defenders (Security Teams): Information gathering shows what attackers can learn about your systems. By performing the same reconnaissance that attackers do, defenders can identify information leakage, unnecessary services, and exposed infrastructure. This allows them to reduce the attack surface by closing unnecessary ports, removing sensitive information from public view, and fixing misconfigurations before attackers find them. It's about seeing your systems through an attacker's eyes.

Part 10: How Websites Work - Request-Response Model

The Request-Response Cycle:

When you type a domain name into your browser and press Enter, a number of events occurs to display the website:

Step 1: Domain Name Entry You type `www.icdfa.edu.ng` into your browser's address bar. Your computer doesn't understand domain names directly, it only works with IP addresses, thus the domain is sent to the DNS.

Step 2: DNS Resolution

The DNS server works like a phone book. It looks up `www.icdfa.edu.ng` and returns the corresponding IP address.

Step 3: Establishing Connection Once your browser has the IP address, it initiates a TCP connection to the web server at that address (usually on port 80 for HTTP or 443 for HTTPS). This involves a three-way handshake (SYN,SYN-ACK,ACK) where your computer and the server agree to communicate.

Step 4: Sending the HTTP Request Your browser sends an HTTP request to the server.

Step 5: Server Processing The web server receives the request and processes it.

Step 6: Sending the HTTP Response The server sends back an HTTP response.

Step 7: Browser Rendering Your browser receives the HTML and starts rendering it. It also sends additional requests for Javascript and other resources required in the same process.

CHALLENGES

Challenge 1: IP Blocking

Problem: Some domains given had robust security implementations making it difficult to gather information from them.

Solution:

- Used their ip address to try get the information. Some were successful and others weren't

Conclusion

This comprehensive web application reconnaissance lab provided essential training in information gathering techniques that form the foundation of professional cybersecurity operations. Through systematic completion of ten distinct sections covering domain reconnaissance, technology fingerprinting, subdomain enumeration, directory discovery, vulnerability scanning, and automation development, practical proficiency was achieved in both passive and active reconnaissance methodologies.

References

1. Kali Linux Documentation. (2024). Kali Linux Official Documentation. Retrieved from <https://www.kali.org/docs/>
2. International Cybersecurity and Digital Forensics Academy. (2024). Lab Assignment Guide - Web Application Reconnaissance.
3. OWASP Foundation. (2024). OWASP Broken Web Applications Project. Retrieved from <https://owasp.org/www-project-broken-web-applications/>
4. Sublist3r GitHub Repository. (2024). Retrieved from <https://github.com/aboul3la/Sublist3r>
5. KnockPy GitHub Repository. (2024). Retrieved from <https://github.com/guelfoweb/knock>